

README KIT INTEGRAL: GQM + PRAGMATIC + ACET

Guía Completa de Implementación, Uso y Gobernanza

Versión: 3.0 | **Fecha:** Enero 2026 | **Alcance:** España, todas las industrias y tamaños

0. DESCRIPCIÓN GENERAL DEL KIT ACTUALIZADO

Este kit es la **evolución del Kit ACET original** (archivos 01-07), incorporando:

1. Metodología GQM+ Strategies (alineación estratégica vertical)
2. Criterios PRAGMATIC (validación 9 dimensiones de cada métrica)
3. Integración completa (Goal → Question → Metric → PRAGMATIC Score)

Componentes Nuevos (Archivos 08-13):

KIT INTEGRAL GQM+PRAGMATIC+ACET (Enero 2026)

- ARCHIVOS ORIGINALES ACET (01-07)
 - 01_Encuesta_Integral.md (60+ preguntas)
 - 02_Guia_Metodologica.md (cálculos IGM, KRIs)
 - 03_Narrativa_Explicativa.md (tono literario irónico)
 - 04_Mapeo_Normativo_v1.md (NIST, ENS, NIS2, GDPR, ISO)
 - 05_Plantilla_Excel_IGM.md (hoja de cálculo básica)
 - 06_Plantilla_PowerPoint.md (15 diapositivas)
 - 07_README_Kit.md (guía original)
- ARCHIVOS NUEVOS GQM+PRAGMATIC (08-13)
 - 08_Marco_GQM_PRAGMATIC.md (teoría + metodología)
 - 09_Matriz_PRAGMATIC_Completa.md (evaluación 25 indicadores)
 - 10_Mapeo_Normativo_v2.md (trazabilidad GQM → requisitos)
 - 11_Plantilla_Excel_Avanzada.md (8 hojas: GQM_MAPPING + PRAGMATIC_EVAL)
 - 12_PowerPoint_GQM_PRAGMATIC.md (18 diapositivas integrativas)
 - 13_README_Kit_v3.md (este archivo)

TOTALIDAD: 13 archivos | ~500 KB contenido profesional

1. ARQUITECTURA DEL KIT

Flujo de Trabajo Recomendado

FASE 1: INVESTIGACIÓN (Semana 1)

- Leer: 08_Marco_GQM_PRAGMATIC.md (entender concepto)
- Revisar: 09_Matriz_PRAGMATIC_Completa.md (validación métricas)
- OUTPUT: Alineación ejecutiva = "Entiendo por qué cada métrica importa"

FASE 2: PREPARACIÓN (Semana 2)

- Usar: 01_Encuesta_Integral.md (distribuir)
- Revisar: 10_Mapeo_Normativo_v2.md (verificar cobertura regulatoria)
- Configurar: 11_Plantilla_Excel_Avanzada.md (8 hojas, fórmulas)
- OUTPUT: Sistema listo para recolectar datos

FASE 3: RECOLECCIÓN (Semanas 2-4)

- Ejecutar: Encuesta a 10-15 respondientes
- Validar: Respuestas contra 07_README_Kit.md (solución problemas)
- Limpiar: Datos en Hoja INPUT de Excel
- OUTPUT: Base datos completa, 60 respuestas validadas

FASE 4: ANÁLISIS (Semana 5)

- Ejecutar: Fórmulas Excel (cálculos automáticos IGM, PRAGMATIC)
- Mapear: Cada pregunta a GQM_MAPPING (hoja 3)
- Evaluar: PRAGMATIC scores (hoja 4)
- Consultar: 02_Guia_Metodologica.md (interpretación)
- OUTPUT: Dashboard Excel con todos KPIs + PRAGMATIC scores

FASE 5: GENERACIÓN REPORTES (Semana 6)

- Crear: PowerPoint 12_PowerPoint_GQM_PRAGMATIC.md (18 dips)
- Escribir: Narrativa 03_Narrativa_Explicativa.md (para ejecutivos)
- Validar: Trazabilidad 10_Mapeo_Normativo_v2.md
- Revisar: Roadmap GQM-alineado (diapositiva 14)
- OUTPUT: Presentación profesional + documentos sustentatorios

FASE 6: COMUNICACIÓN & GOBERNANZA (Semana 7-8)

- Presentar: 12_PowerPoint_GQM_PRAGMATIC.md a Junta
- Obtener: Aprobación presupuesto (€530K año 1)
- Designar: Propietarios por Meta Medición (GQM niveles 0-2)
- Establecer: Monitoreo mensual/trimestral (diapositiva 17)
- OUTPUT: Plan aprobado, gobernanza activa, presupuesto asignado

2. GUÍA POR ARCHIVO (VERSIÓN 3.0)

ARCHIVOS ORIGINALES (01-07): Resumen Rápido

01_Encuesta_Integral.md

- 60+ preguntas en 8 bloques (GV, ID, PR, DE, RS, RC, VA, SIEM, CAP)
- Uso: Instrumento recolección datos
- Tiempo respondiente: 45-90 minutos
- Formato: Copiar a Google Forms, MS Forms, Qualtrics

02_Guia_Metodologica.md

- Cálculo IGM, KRIs, KPIs, ROI, benchmarking
- Niveles ACET (Ad Hoc – Innovative)

- Interpretación de resultados
- Uso: Referencia análisis

03_Narrativa_Explicativa.md

- Explicación constructiva, irónica, amena
- Contexto estratégico, analogías
- Uso: Resumen ejecutivo, comunicación

04_Mapeo_Normativo_v1.md

- Trazabilidad: pregunta – artículos NIST, ENS, NIS2, GDPR, ISO
- Uso: Auditorías regulatorias

05_Plantilla_Excel_IGM.md

- 5 hojas: INPUT, SCORING, BENCHMARKING, ROI, DASHBOARD
- Fórmulas cálculo IGM básicas
- Uso: Cálculos y dashboards

06_Plantilla_PowerPoint.md

- 15 diapositivas estructura ACET
- Uso: Presentación estándar

07_README_Kit.md

- Guía implementación 12 pasos
- Mejores prácticas, FAQ, solución problemas
- Roadmap 3 años

ARCHIVOS NUEVOS (08-13): GQM + PRAGMATIC

08_Marco_GQM_PRAGMATIC.md ★ **CONCEPTUAL (LEER PRIMERO)**

Propósito: Comprender filosofía GQM + PRAGMATIC

Contenido:

- Desconexión clásica: CEO goal ≠ CISO tactic ≠ SOC data
- Estructura 4 niveles GQM (BG → SG → MG → Metric)
- 9 Criterios PRAGMATIC con ejemplos
- Matriz GQM completa dominio DETECTAR (ejemplo end-to-end)

Cuándo usar:

- Inicio proyecto: Leer completo (30 min)
- Justificar a ejecutivos: Mostrar Problema (slide "Desconexión")
- Entrenar equipo: Usar como material educativo

Output: Todos entiendan por qué cada métrica conecta a objetivo negocio

09_Matriz_PRAGMATIC_Completa.md ★ EVALUACIÓN INTEGRAL

Propósito: Validar calidad de cada indicador contra 9 criterios

Contenido:

- 25 indicadores ACET mapeados
- Cada indicador: 9 criterios × 0-3 puntos = Score/27 = %PRAGMATIC
- Interpretación: >90% Excel | 80-90% Bueno | 70-80% Aceptable | <70% Pobre
- Promedio: 90% PRAGMATIC = Cartera robusta

Ejemplo:

Indicador: MTTD <2 horas

P (Predictivo): 3/3 ✓ (predice daño controlado)
R (Relevante): 3/3 ✓ (CEO vigila)
A (Accionable): 3/3 ✓ (Si >2h = tune SIEM)
G (Genuino): 2/3 ⚠ (Requiere validar falsos positivos)
S (Significativo): 3/3 ✓ (€5K-10K/hora delay)
Pr (Preciso): 3/3 ✓ (Timestamp automático)
O (Oportuno): 3/3 ✓ (Real-time SIEM)
I (Independiente): 2/3 ⚠ (Requiere auditoría externa)
Re (Rentable): 3/3 ✓ (€0 colección)

TOTAL: 25/27 = 93% PRAGMATIC ✓ IMPLEMENTAR

Cuándo usar:

- Priorizar indicadores: Implementar primero >90%
- Validación cruzada: Para <85%, añadir auditoría técnica
- Aprobación inversión: "25 de 25 indicadores validan 90% criterios PRAGMATIC"

10_Mapeo_Normativo_v2.md ★ TRAZABILIDAD REGULATORIA

Propósito: Conectar cada pregunta → requisitos normativos + GQM Level

Contenido:

- Matriz 60+ preguntas × 5 marcos (NIST, ENS, NIS2, GDPR, ISO)
- Incluye: ID pregunta | Texto | Dominio | NIST CSF | ENS | NIS2 | GDPR | ISO 27001 | Artículos | Evidencia esperada

Ejemplo:

P4.2.1 | ¿MTTD <2h? | DE | ✓DE-4 | ✓D.4 | ✓Art.21 | ✓Art.32 | ✓8.4.4
Artículos: NIST DE-4; ENS D.4; NIS2 Art.21; GDPR Art.32; ISO 8.4.4
Evidencia: SIEM dashboard MTTD metric

Cuándo usar:

- Auditor pregunta: "¿Cómo cumple Art. 18 NIS2?" → Buscar en matriz → 6 preguntas
- Demostrativo: "Encuesta valida 95%+ requisitos GDPR"
- Regulador solicita prueba: Mostrar matriz de trazabilidad

11_Plantilla_Excel_Avanzada.md ★ IMPLEMENTACIÓN TÉCNICA

Propósito: Sistema cálculo integral con 8 hojas especializadas

Estructura 8 Hojas:

4. INPUT: 60 respuestas + puntos + GQM_level + PRAGMATIC_score
5. SCORING: IGM global, índices complementarios (VAS, SES, SATS), KRIs
6. GQM_MAPPING: Trazabilidad BG→SG→MG→Q→Metric (para gobernanza)
7. PRAGMATIC_EVAL: Matriz 9 criterios × 25 indicadores
8. BENCHMARKING: Comparativa sector/nacional + Radar chart
9. ROI_ANALYSIS: Controles, inversión, beneficio, payback, ROI%, prioridad
10. NORMATIVE_MAPPING: Pregunta → NIST/ENS/NIS2/GDPR/ISO
11. DASHBOARD_EXECUTIVE: Visualización resumen (Gauge, Radar, KRIs, Roadmap)

Fórmulas Clave:

$$\text{IGM} = (\text{GV}\% \times 0.15 + \text{ID}\% \times 0.15 + \text{PR}\% \times 0.25 + \text{DE}\% \times 0.20 + \text{RS}\% \times 0.15 + \text{RC}\% \times 0.10)$$
$$\text{PRAGMATIC_Score} = \text{SUM}(\text{P}, \text{R}, \text{A}, \text{G}, \text{S}, \text{Pr}, \text{O}, \text{I}, \text{Re}) / 27 \times 100$$
$$\text{ROI}\% = ((\text{Beneficio} - \text{Inversión}) / \text{Inversión}) \times 100$$
$$\text{Payback} = (\text{Inversión} / \text{Beneficio Anual}) \times 12 \text{ meses}$$

Cuándo usar:

- Importar respuestas encuesta → Excel automático calcula todo
- Reportar IGM + PRAGMATIC scores + ROI en tiempo real
- Compartir dashboard con ejecutivos

Output: Fichero Excel profesional listo para distribución

12_PowerPoint_GQM_PRAGMATIC.md ★ COMUNICACIÓN EJECUTIVA

Propósito: Presentación 18 diapositivas integrada GQM+PRAGMATIC

Estructura:

- D1: Portada (IGM 71%, Framework GQM+PRAGMATIC)
- D2: Agenda
- D3: Resumen Ejecutivo (3 columnas: Posición, Alineación, Recomendación)
- D4: Innovación Metodológica (Problema → Solución GQM)
- D5: GQM Explicado (Step-by-step Goal→Question→Metric)
- D6: PRAGMATIC 9 Criterios (Grid visual 3×3)
- D7: Matriz PRAGMATIC 25 Indicadores (Tabla resumen scores)
- D8-13: [Contenido ACET estándar: IGM, Radar, Benchmarking, KRIs, VA, SIEM]
- D14: GQM Roadmap (Q1-Q4 2026 con Goals, Metrics, Inversión, ROI)
- D15: Gobernanza GQM Sostenible (Niveles, Frecuencias, Responsables)
- D16: Recomendaciones Ejecutivas (Top 3 acciones 30 días)

- D17: Scorecard Trimestral (KPIs targets por trimestre)
- D18: Cierre + Q&A

Diferencia vs. 06_PowerPoint.md:

- Antes: Énfasis en "qué medimos" (resultados ACET)
- Ahora: Énfasis en "por qué medimos" (Goal–Metric trazabilidad) + PRAGMATIC validation

Cuándo usar:

- Presentación Junta/Ejecutivos (30-40 min)
- Educación: Explicar valor GQM+PRAGMATIC methodology
- Aprobación presupuesto: Mostrar ROI análisis alineado a goals

13_README_Kit_v3.md (Este archivo)

Propósito: Guía implementación, arquitectura, gobernanza

Secciones:

- Descripción general kit v3
- Arquitectura workflow 6 fases
- Guía por archivo
- Gobernanza GQM sostenible
- Mejores prácticas
- Solución problemas
- Roadmap mantenimiento

3. GOBERNANZA GQM SOSTENIBLE

Estructura Niveles

NIVEL 0: BUSINESS GOAL (Junta/CEO)

- Ejemplos: "Mejorar NPS 25%", "Cumplir NIS2", "Reducir riesgos 30%"
- Frecuencia Revisión: Anual
- Propietario: CEO/CFO
- Métrica: Correlación con objetivos ejecutivos

NIVEL 1: SECURITY GOAL (CISO/CIO)

- Ejemplos: "MTTD <2h", "Capacitación >95%", "Backups 3-2-1"
- Frecuencia Revisión: Trimestral
- Propietario: CISO + IT Director
- Métrica: Alineación con Security Goals

NIVEL 2: MEASUREMENT GOAL (SOC Lead)

- Ejemplos: "Cobertura SIEM >85%", "Correlación >60%", "IGM $\geq$ 75%"
- Frecuencia Revisión: Mensual
- Propietario: SOC Lead + Security Team
- Métrica: Avance vs. Target Measurement Goals

NIVEL 3: METRICS (Analytics)

- Ejemplos: MTTD, SIEM_Cov%, Phishing_ClickRate
- Frecuencia Revisión: Real-time (dashboards) + Semanal (reportes)
- Propietario: Data Analyst + SOC Analyst
- Métrica: Cumplimiento SLA métrica, PRAGMATIC score >90%

Calendario Operativo

Mensual:

- Reunión SOC (Lunes 1er semana): Revisar Metrics, KRIs, alertas
- Output: KPI report para CISO

Trimestral:

- Reunión CISO + IT (1a semana): Revisar Measurement Goals, proyección IGM
- Output: Roadmap ajustes, presupuesto remanente

Anual:

- Reunión Junta (diciembre): Revisión Business Goals, IGM anual, aprobación presupuesto 2027
- Output: Plan estratégico ciberseguridad 2027

Documentos Gobernanza

Mantener Actualizados:

- GQM Framework Document (08_Marco) → Revisar anual
- PRAGMATIC Eval Matrix (09_Matriz) → Revisar bianual
- Encuesta ACET (01_Encuesta) → Actualizar anual (preguntas nuevas?)
- Excel Dashboard (11_Plantilla) → Actualizar mensual (datos)
- Roadmap GQM (12_PowerPoint D14) → Revisar trimestral

4. MEJORES PRÁCTICAS GQM+PRAGMATIC

Para Recolección Datos

✓ **Hacer:**

- Triangular respuestas: IT + CISO + Negocio (3 perspectivas mínimo)
- Validar PRAGMATIC score con auditor técnico (para <85%)
- Documentar supuestos y limitaciones
- Permitir "DK" (Desconoce) sin penalizar

✗ **NO hacer:**

- Aceptar "Sí" sin evidencia
- Mezclar niveles GQM (pregunta debe mapear a single level)
- Cambiar preguntas mid-stream
- Penalizar respondentes por DK alto

Para Análisis

✓ **Hacer:**

- Validar IGM con scan técnico independiente (Nessus, etc.)
- Para PRAGMATIC <85%, incluir auditoría cruzada
- Reconciliar discrepancias entre respondentes
- Investigar "outliers" (ej. "Sí SIEM" pero "No" correlación)

✗ **NO hacer:**

- Asumir linealidad: IGM 71% ≠ Riesgo 29% (NO son opuestos)
- Comparar directamente con competidores (contextos distintos)
- Publicar scores individuales por respondente (privacidad)
- Ignorar "NA" (puede indicar falta de visibilidad)

Para Gobernanza

✓ **Hacer:**

- Asignar propietarios explícitos para cada nivel GQM
- Calendarizar revisiones: Real-time (Metrics) – Anual (Goals)
- Conectar compensation/incentives a SGs/MGs (si aplica)
- Documentar decisiones, cambios, excepciones

✗ **NO hacer:**

- Dejar métricas sin dueño (– abandono)
- Revisar solo IGM global (perder granularidad)
- Cambiar ponderaciones de dominios sin documentar razón
- Implementar 50 iniciativas sin priorizar (parálisis)

5. SOLUCIÓN DE PROBLEMAS

Problema: PRAGMATIC Score Bajo (<75%) para Métrica Importante

Diagnóstico:

Causas Comunes:

1. Métrica "Genuina" baja: ¿Mide qué pretende o hay sesgo?
2. Métrica "Independiente" baja: ¿Verificable objetivamente?
3. Métrica "Oportuno" baja: ¿Datos disponibles rápido?

Soluciones:

1. Añadir validación técnica independiente (ej. auditor externo)
2. Automatizar colección (reducir sesgo manual)
3. Documentar "Notas de Auditoría" (limitaciones conocidas)
4. Aceptar si score >70% + hay compensación otras métricas

Problema: GQM Levels No Alineados (Pregunta mapea a 2 niveles)

Diagnóstico:

Ejemplo: P4.2.1 ("¿MTTD <2h?")

¿Mapea a?: MG (Measurement Goal) o Q (Question)?

→ Ambigüedad

Solución:

1. Clarificar: MTTD es MÉTRICA (Nivel 3), no Question
2. Question sería: "¿Detectamos ataques en <2 horas?"
3. Métrica: "MTTD = [timestamp diff] en horas"
4. Documentar distinción en 08_Marco_GQM_PRAGMATIC.md

Problema: ROI Analysis Muestra Payback >12 Meses

Diagnóstico:

Ejemplo: SIEM costó €150K, beneficio €180K → Payback 10 meses ✓

Pero EDR costó €120K, beneficio €80K → Payback 18 meses ✗

Decisión:

1. Si payback >12 meses: Cuestionar justificación
2. Opciones:
 - a. Rechazar iniciativa (no justificable ROI económico)
 - b. Aceptar por razón regulatoria (ej. GDPR compliance)
 - c. Reestructurar: Fase 1 (€50K, payback 8m) + Fase 2 (€70K, posterior)

6. FAQ

¿Puedo usar solo archivos 01-07 (Kit ACET original)?

Respuesta: Sí, funciona. Pero pierde:

- Trazabilidad Goal—Metric (no sabes por qué cada métrica)

- Validación PRAGMATIC (no sabes si métrica es realmente útil)
- Alineación negocio (dificultad justificar presupuesto)

Recomendación: Mínimo leer 08_Marco + usar 09_Matriz para validación.

¿Qué diferencia hay entre GQM original (Basili) y GQM+?

Respuesta:

Aspecto	GQM Original	GQM+ Strategies
Niveles	3 (Goal, Q, M)	4 (BG, SG, MG, Q/M)
Alineación	Local (equipo)	Global (empresa)
Uso	Medición táctico	Gobernanza estratégica
Implementación	Medio	Alto

Este kit usa **GQM+**, más ambicioso pero más justificable.

¿Cuánto tiempo requiere implementar todo?

Respuesta:

Fase	Tiempo	Personas
Investigación (Leer marcos)	5h	2 (CISO, Analyst)
Preparación (Configurar Excel)	10h	1 (Analyst)
Recolección (Encuesta)	15h	3 (Distribución + seguimiento)
Análisis (Cálculos + validación)	20h	2 (Analyst + Auditor)
Reportes (PowerPoint + narrativa)	15h	1 (Analyst)
TOTAL	65h	~3 personas semana

Aceleración:

- Solo 01_Encuesta + 02_Guia + 05_Excel: 30h (rápido pero menos profundo)
- Completo (01-13): 65h (robusto)

¿Es obligatorio usar Excel avanzada (11_Plantilla)?

Respuesta: No, alternativas:

- Google Sheets (similar estructura, gratis, colaborativo)
- Power BI (si ya tenéis, más visual)
- Salesforce (si CRM store datos)
- Manual Excel (usar 05_Plantilla básica + cálculos manuales)

Recomendación: 11_Plantilla avanzada si >3 usuarios, >50 preguntas, necesita automatización.

7. ROADMAP MANTENIMIENTO KIT

Q1 2026: Validación Post-Implementación

- Recopilar feedback usuarios
- Documentar lecciones aprendidas
- Versión 3.1: Correcciones menores

Q2 2026: Integraciones

- Conectar QM framework a CMMC (si defense contractors)
- Añadir preguntas post-quantum (cryptography)
- Actualizar benchmarks INCIBE 2026

Q3 2026: Especialización Sectorial

- Variantes kit para: Finanzas, Sanitaria, Manufactura, Energía, Telecom
- Cada sector: Preguntas específicas OT/ICS, regulaciones locales

Q4 2026: Gobernanza Evolucionada

- Integración QM a COBIT 2023 (governance IT)
- Conexión a Balanced Scorecard (BSC)
- Modelo sostenibilidad 3+ años

8. CONTACTO & SOPORTE

Para reportar bugs, sugerencias, adaptaciones:

- Email: [respuesta@ciberseguridad.es]
- Forum: [comunidad.isms-forum.es/gqm-pragmatic]
- Versión Actual: 3.0 (Enero 2026)
- Próxima Release: Q2 2026

KIT LISTO PARA IMPLEMENTACIÓN. COMIENZA HOY.